DEVPATH PLATFORM ARCHITECTURE

Authentication Microservice Report

Activity 4 & Evidence 4 Technical Specification (Unit 3)

Executive Summary: Technical report for the **DevPath Authentication System**. DevPath is a software career platform built with React + Vite, Express backend API, custom Skill Matching microservice, PostgreSQL database, and JSearch API. The system utilizes **JSON Web Tokens (JWT)** and HTTP-only cookies.

1. AUTHENTICATION MECHANISM & ARCHITECTURAL JUSTIFICATION

DevPath selected a **JSON Web Token (JWT)** stateless authentication mechanism over server-side sessions. In a distributed microservices environment where the *Main Backend API* and *Skill Engine* scale independently, stateless JWT validation eliminates session lookup bottlenecks in PostgreSQL.

Dimension	Custom Auth Microservice (Implemented)	Third-Party Provider (Auth0 / Firebase)
Data Sovereignty & Control	Full control over user schemas, credential storage, custom claims, and audit logs in PostgreSQL.	User data housed externally; customization constrained by vendor schemas.
Operational Complexity	Requires maintaining cryptographic algorithms, token rotation logic, and cookie handling.	Offloads maintenance, server infrastructure, and compliance to a managed SaaS platform.
Vendor Lock-in & Cost	Zero subscription licensing costs; deployable across any cloud infrastructure.	Free tier limits followed by scalable per-MAU pricing tiers.
Security Responsibility	Development team manages secret storage, rate limiting, and vulnerability patching.	Outsources identity security, MFA pipelines, and anomaly detection to vendor experts.

2. AUTHENTICATION SEQUENCE WORKFLOWS

2.1 Login and Token Issuance Sequence

The login workflow verifies user credentials against cryptographic hashes in PostgreSQL and issues paired access and refresh tokens.

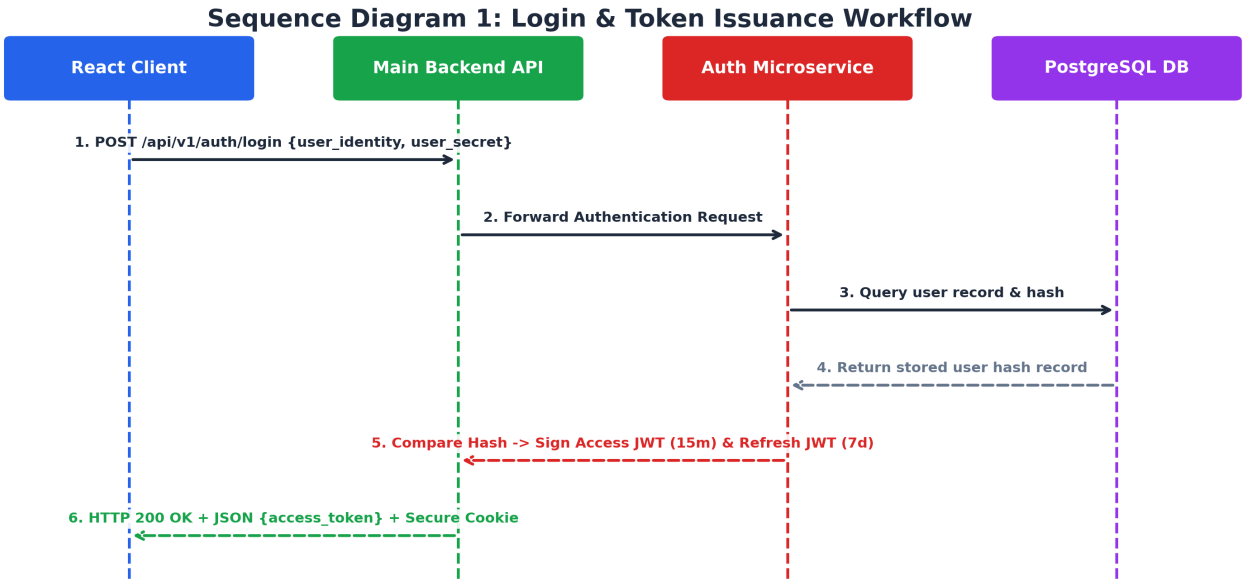


Figure 1: Sequence Diagram detailing credential validation and dual token issuance.

2.2 Protected Request Execution Sequence

Protected endpoints in the Skill Engine validate the client Bearer JWT locally without calling the Auth Microservice.

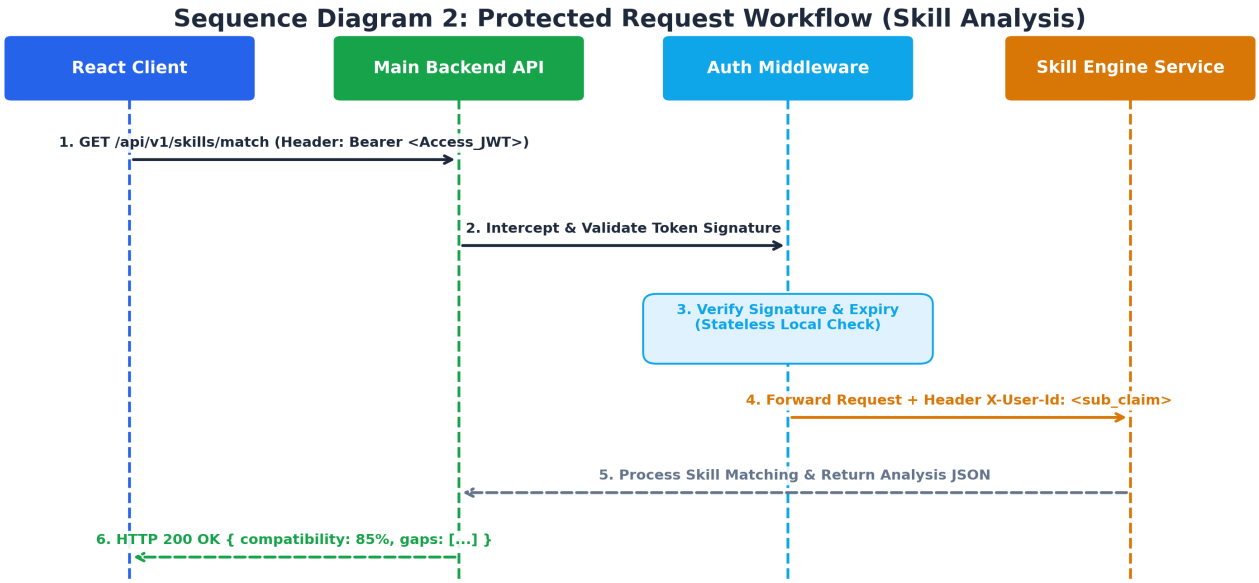


Figure 2: Sequence Diagram illustrating stateless token verification across microservice boundaries.

3. TOKEN CLAIMS, LIFECYCLE & REVOCATION STRATEGY

DevPath enforces a dual-token policy: short-lived **Access Tokens (15 minutes)** for request headers, and long-lived **Refresh Tokens (7 days)** stored in secure HTTP cookies.

JWT Access Token Claims Structure:

```
{
  "sub": "user_id_uuid",                 // Unique Subject Identifier
  "identity": "user_account",             // User Identity Claim
  "role": "candidate",                     // RBAC Role
  "iss": "devpath_auth_service",           // Issuer Identifier
  "exp": 1761847066                         // Token Expiration Timestamp
}
```

Token Type	Lifetime	Storage Location	Renewal Strategy
Access Token	15 Minutes	Client In-Memory State	Renewed via refresh token before expiry.
Refresh Token	7 Days	Secure HTTP Cookie	Rotated on each refresh request.
Logout Strategy	Immediate	Session Cleared	Cookie purged and refresh token revoked.

4. SYSTEM ARCHITECTURE & COMPONENT INTERFACE CONTRACTS

4.1 Architectural Component Map

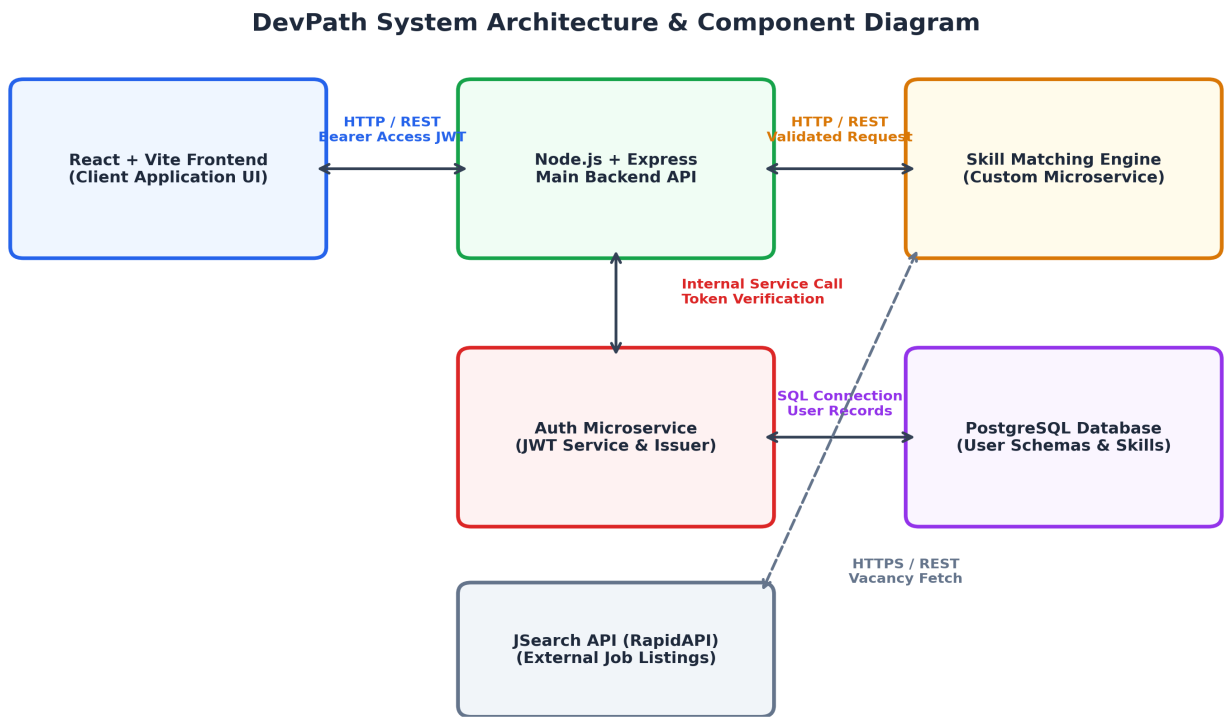


Figure 3: DevPath System Component Integration Diagram showing request paths and API boundaries.

4.2 Inter-Component Data & Endpoint Contracts

Pair (Source -> Target)	HTTP Method & Route	Request Payload & Headers	Response Status & Format
React Frontend -> Auth Microservice	POST /api/v1/auth	Body: JSON Auth Credentials Header: Content-Type: application/json	200 OK Token Response 401 Auth Refused 429 Rate Exceeded
React Frontend -> Main Backend API	GET /api/v1/skills	Header: Authorization Bearer Token	200 OK User Skills Data 401 Token Expired 403 Role Forbidden
Main Backend -> Skill Engine	POST /api/v1/analyze	Header: X-User-Id claim Body: Vacancy text JSON	200 OK Matching JSON 400 Invalid Input 503 Service Unavailable
Skill Engine -> JSearch API	GET /search?query=Junior	Headers: RapidAPI Key & Host	200 OK Vacancies Data 429 Rate Limit 500 Service Outage

5. FAILURE MODES & GRACEFUL DEGRADATION STRATEGIES

Distributed systems must withstand partial outages. DevPath implements fault isolation mechanisms to maintain UI functionality even when individual microservices, databases, or external APIs fail.

Failed Component	Direct Impact on System	Mitigation & Degradation Strategy
Auth Microservice Unreachable	New user logins, registrations, and token refresh requests fail.	Existing authenticated clients remain operational for active access token duration (15m). Main API verifies JWTs statelessly.
PostgreSQL Database Down	Stateful reads/writes fail (user profiles, saved paths, credentials).	Main API returns HTTP 503 Service Unavailable with retry-after headers. Frontend displays friendly maintenance alert.
JSearch API Outage	Live vacancy fetching fails during skill gap analysis.	Skill Matching Engine catches API exceptions and falls back to cached job vacancy datasets stored locally.

6. APPLIED SECURITY CONTROLS & OWASP RISK ASSESSMENT

DevPath incorporates industry-standard security controls including cryptographic password hashing (cost factor 12), HTTPS/TLS encryption, environment variable secret separation, and secure cookie attributes.

OWASP Category (2025)	Security Focus	Applied Control & Mitigation
A01: Access Control Security	Resource Isolation & Access Limits	Auth Middleware validates token sub claim against requested resource IDs in database queries.
A02: Cryptographic Security	Credential Storage & Key Protection	Passwords hashed with salted algorithms (cost 12+). JWTs signed using strong 256-bit secret key managed via isolated environment variables.
A03: Input & Query Security	Query Sanitization & DOM Protection	PostgreSQL queries use parameterized statements. JWT refresh tokens stored in secure cookies inaccessible to client scripts.
A05: Configuration Security	Environment Hardening & Error Handling	Global error handlers sanitize output to client (returning structured JSON without stack traces). CORS policy restricted to specific origins.
A08: Session & Data Integrity	Session Security & Token Rotation	Short 15-minute expiration on access tokens. Refresh tokens subject to strict single-use rotation and immediate revocation.

7. EVIDENCE & VERIFICATION COMPLIANCE

Repository Verification: The implementation details, request collections, and microservice source code are maintained within the project repository under the tag e3-microservice. Setup instructions, environment configuration details, and test suites are documented in accordance with Unit 3 Evidences 3 and 4 evaluation criteria.